

# SOC - Sysmon et Traçabilité Hybride

## Objectifs :

- Comprendre les angles morts (Blind spots) de la journalisation Windows native.
- Déployer et configurer System Monitor (Sysmon) avec un filtrage chirurgical (SwiftOnSecurity).
- Comprendre l'architecture de collecte croisée (Windows vers SIEM Linux).
- Identifier les événements critiques de compromission (Event IDs) traqués par l'ANSSI.

## 1. Les limites de la journalisation Windows Native

Par défaut, l'Observateur d'événements de Windows (Event Viewer) est conçu pour le dépannage informatique (Troubleshooting), pas pour la traque de cyberattaques (Threat Hunting).

### 1.1 L'aveuglement face au "Living off the Land" (LotL)

Si un attaquant utilise une macro Word pour lancer PowerShell de manière furtive et télécharger un ransomware, voici ce que voit le journal de sécurité Windows natif (Event ID 4688 - Process Creation) :

- Un processus `powershell.exe` a été lancé.

#### Ce qu'il manque :

- La ligne de commande exacte (les arguments étaient-ils obfusqués en Base64 ?).
- Le hash cryptographique (SHA256) de l'exécutable.
- Le parent exact (Est-ce `explorer.exe` ou `winword.exe` qui a lancé PowerShell ?).

## 2. Sysmon

**Sysmon (System Monitor)** est un service système et un pilote de périphérique (Driver). Une fois installé, il reste résident à travers les redémarrages et enregistre l'activité du système dans le journal d'événements Windows avec un niveau de détail chirurgical.

## 2.1 Le fonctionnement bas niveau (Driver)

Contrairement à un logiciel classique qui "écoute", Sysmon s'insère directement dans le noyau Windows (Ring 0) via des Callouts et des Minifilters. Il intercepte les appels système (Syscalls) avant même qu'ils ne soient traités, ce qui le rend très difficile à aveugler pour un attaquant standard.

## 2.2 La nécessité du Filtrage (Le profil SwiftOnSecurity)

Si l'on installe Sysmon sans configuration, il va générer des dizaines de milliers d'événements par minute (chaque connexion réseau, chaque fichier lu). Cela va écrouler le serveur et saturer le SIEM (SOC).

L'architecture nécessite un fichier de configuration XML pour filtrer le bruit légitime. Le standard de l'industrie est la configuration **SwiftOnSecurity** :

- Elle **exclut** le bruit de fond (ex: les requêtes DNS de Windows Update, les connexions réseau de Spotify ou OneDrive).
- Elle **inclut** spécifiquement les comportements suspects (ex: `cmd.exe` lançant `powershell.exe`, création de fichiers `.exe` dans le dossier `C:\Users\Public`).

## 3. Centralisation des Logs

L'ANSSI est formelle : **"Un journal stocké uniquement sur la machine qui l'a généré n'a aucune valeur de sécurité"**. Si un attaquant devient Administrateur du Domaine, sa première action sera de taper `wevtutil cl Security` pour vider les journaux.

### 3.1 La collecte croisée (Cross-Platform)

Dans un environnement moderne, le Bastion d'administration ou le collecteur SOC (SIEM) tourne souvent sous Linux (Splunk, ELK, QRadar, Rsyslog).

Windows parle en XML/EventLog, Linux parle en Syslog/JSON. **La solution** : L'utilisation d'un agent de transfert léger (Forwarder) comme **NXLog**, **Winlogbeat** ou **Splunk Universal Forwarder** sur le serveur Windows.

1. Sysmon génère l'alerte sur le Contrôleur de Domaine (Windows).
2. L'agent (ex: NXLog) capte l'alerte, la convertit en format JSON (structuré).
3. L'agent l'envoie de manière chiffrée (TLS) vers le collecteur Syslog du serveur Linux.
4. L'attaquant détruit le Contrôleur de Domaine, mais la preuve est déjà en sécurité sur le Bastion Linux.

## 4. hreat Hunter (Les Event IDs Sysmon)

Une fois Sysmon déployé (dans *Journaux des applications et des services > Microsoft > Windows > Sysmon > Operational*), l'analyste SOC traque des identifiants d'événements (Event ID) très spécifiques :

- **Event ID 1 : Process Creation (Le Saint Graal)**
  - Fournit la ligne de commande complète, le hachage SHA256 (pour vérifier sur VirusTotal) et le GUID du processus parent.
  - Cas d'usage : Détecter une commande encodée en Base64 passée à *powershell.exe -e*.
- **Event ID 3 : Network Connection**
  - Associe une connexion TCP/UDP à un processus précis.
  - Cas d'usage : Détecter la calculatrice (*calc.exe*) ou un processus système (*lsass.exe*) qui tente de se connecter à une adresse IP externe en Russie.
- **Event ID 8 : CreateRemoteThread**
  - Détecte lorsqu'un processus A injecte du code dans la mémoire du processus B.
  - Cas d'usage : C'est la technique reine des malwares (Cobalt Strike, Mimikatz) pour se cacher dans *explorer.exe* (Fileless Malware).
- **Event ID 11 : FileCreate**
  - Détecte la création de fichiers. Utile si filtré sur les dossiers à risque (ex: le dossier de démarrage ou *C:\Windows\Temp*).
- **Event ID 22 : DNSEvent**
  - Enregistre les requêtes DNS (Résolution de noms).
  - Cas d'usage : Détecter un ransomware qui tente de contacter son serveur de commande (C2) généré aléatoirement (DGA).

Le durcissement prévient l'attaque, mais Sysmon permet de réagir lorsque la prévention a échoué.